DEPARTAMENTO:	**Ciencias de la Computación**	**CARRERA:**	**SOFTWARE**		
ASIGNATURA:	Software Seguro	**NIVEL:**	7mo	**FECHA:**	12/10/2026
DOCENTE:	Ing. Ángel Cudco	**TAREA N°:**	2	**CALIFICACIÓN:**	

Actividad de Aprendizaje: SGSI del Proyecto Integrador

Zaith Alejandro Manangón Vinueza
Stefany Maricela Díaz Antun
Andrés Isaias Cedeño Cuenca

1. Antecedentes

PROYECTO INTEGRADOR

El proyecto integrador consiste en el diseño, desarrollo y evaluación de una aplicación de salas de chat seguras, orientada a aplicar de manera práctica los principios de desarrollo seguro de software, protección de comunicaciones, control de acceso y seguridad de contenidos multimedia.

La solución deberá permitir que un administrador autenticado mediante usuario y contraseña gestione las salas de comunicación. El administrador podrá crear nuevas salas especificando un identificador único, clave de acceso, número máximo de participantes y el tipo de comunicación permitido, que podrá ser texto, multimedia o ambos.

Cada usuario deberá conectarse a una sala desde un único dispositivo, implementando los mecanismos necesarios para controlar las sesiones activas y evitar conexiones simultáneas no autorizadas. El acceso a cada sala deberá estar condicionado a la validación de su identificador y clave correspondiente.

Toda la información intercambiada dentro de las salas deberá protegerse mediante mecanismos criptográficos, garantizando como mínimo la confidencialidad, integridad y autenticidad de las comunicaciones. El equipo deberá justificar los algoritmos, protocolos, mecanismos de gestión de claves y controles implementados para proteger los mensajes durante su transmisión.

Para las salas que permitan contenido multimedia, la aplicación deberá incorporar un mecanismo de análisis y validación de archivos. Como requerimiento particular de seguridad, el sistema deberá ser capaz de identificar archivos sospechosos o modificados mediante técnicas de esteganografía, generando alertas, registros de auditoría y aplicando una política definida por el equipo, como bloqueo, cuarentena o rechazo del archivo.

2. Desarrollo

2.1. Contexto y alcance

Organización: Sistema de comunicación digital mediante salas de chat seguras.
Alcance del SGSI: Aplicación de salas de chat, gestión administrativa, autenticación de usuarios, control de sesiones, comunicaciones cifradas, transferencia de archivos multimedia y mecanismos de auditoría.

Activos críticos: Credenciales, mensajes, archivos multimedia, claves criptográficas, sesiones, información de salas y disponibilidad del servicio.

2.2. Método de análisis

2.2.1. Activos, amenazas y vulnerabilidades

N.º	Activo (categoría)	Amenaza específica	Vulnerabilidad específica
1	Claves de acceso de las salas privadas (Información)	Obtención de claves de salas mediante una filtración de la configuración.	Las claves se almacenan en texto plano dentro de los registros de configuración de las salas.
2	Claves criptográficas de las comunicaciones (Información)	Exposición de claves utilizadas para proteger los mensajes.	Las claves criptográficas se encuentran incorporadas directamente en el código fuente del proyecto.
3	Registros de auditoría de ingreso y salida de salas (Información)	Eliminación de evidencias de accesos no autorizados.	Los registros pueden ser modificados o eliminados por la misma cuenta que ejecuta la aplicación.
4	Módulo de autenticación del administrador (Software)	Ataque de fuerza bruta contra las credenciales administrativas.	El módulo permite intentos ilimitados de inicio de sesión sin bloqueo temporal.
5	Módulo de autorización para crear y modificar salas (Software)	Creación o modificación de salas por usuarios sin privilegios administrativos.	Los endpoints administrativos validan la autenticación, pero no comprueban el rol del solicitante.
6	Módulo de detección de esteganografía en imágenes (Software)	Ingreso de imágenes con información oculta sin generar alertas de seguridad.	El módulo analiza únicamente extensiones y metadatos, sin inspeccionar posibles alteraciones esteganográficas del contenido.
7	Servicio de mensajería en tiempo real (Servicio)	Interceptación de mensajes intercambiados entre participantes.	El servicio permite conexiones WebSocket sin cifrado mediante ws://.

8	Servicio de ingreso a salas privadas (Servicio)	Acceso automatizado a salas mediante pruebas sucesivas de claves.	El servicio no limita los intentos fallidos de ingreso a una sala.
9	Servicio de transferencia de archivos multimedia (Servicio)	Distribución de archivos maliciosos disfrazados de imágenes.	El servicio válida únicamente la extensión del archivo y no comprueba su contenido real.
10	Servidor de aplicaciones que mantiene las conexiones de chat (Infraestructura)	Saturación de conexiones que provoca la indisponibilidad de las salas.	El servidor no establece límites de conexiones simultáneas por cliente.
11	Servidor de base de datos de salas y usuarios (Infraestructura)	Acceso no autorizado a la base de datos mediante credenciales de la aplicación comprometidas.	La cuenta de conexión de la aplicación posee permisos administrativos innecesarios sobre la base de datos.
12	Directorio de almacenamiento de archivos multimedia (Infraestructura)	Descarga de archivos privados mediante acceso directo a sus direcciones.	El directorio de archivos compartidos está expuesto públicamente sin validación de permisos por sala.
13	Datos de sesiones activas por usuario y dispositivo (Datos)	Uso simultáneo de una cuenta desde dos dispositivos diferentes.	El registro de una nueva sesión no comprueba si existe otra sesión activa del mismo usuario.
14	Datos de mensajes asociados a cada sala (Datos)	Alteración o inserción de mensajes en una sala a la que el remitente no pertenece.	El backend acepta el identificador de sala enviado por el cliente sin verificar su pertenencia a ella.
15	Datos de configuración del cupo máximo de participantes (Datos)	Superación del número máximo de usuarios permitido en una sala.	La verificación del cupo y el registro de nuevos participantes se ejecutan por separado, sin control de concurrencia.

Tabla 1. Activos, Amenazas y vulnerabilidades

2.2.2. Análisis de Riesgo

Método de cálculo:

$$R = P \, x \, I$$

Donde P representa la probabilidad de ocurrencia e I el impacto que tendría la materialización de la amenaza. Ambos se valoran del 1 al 5, obteniendo un nivel de riesgo entre 1 y 25, basándonos en la siguiente matriz:

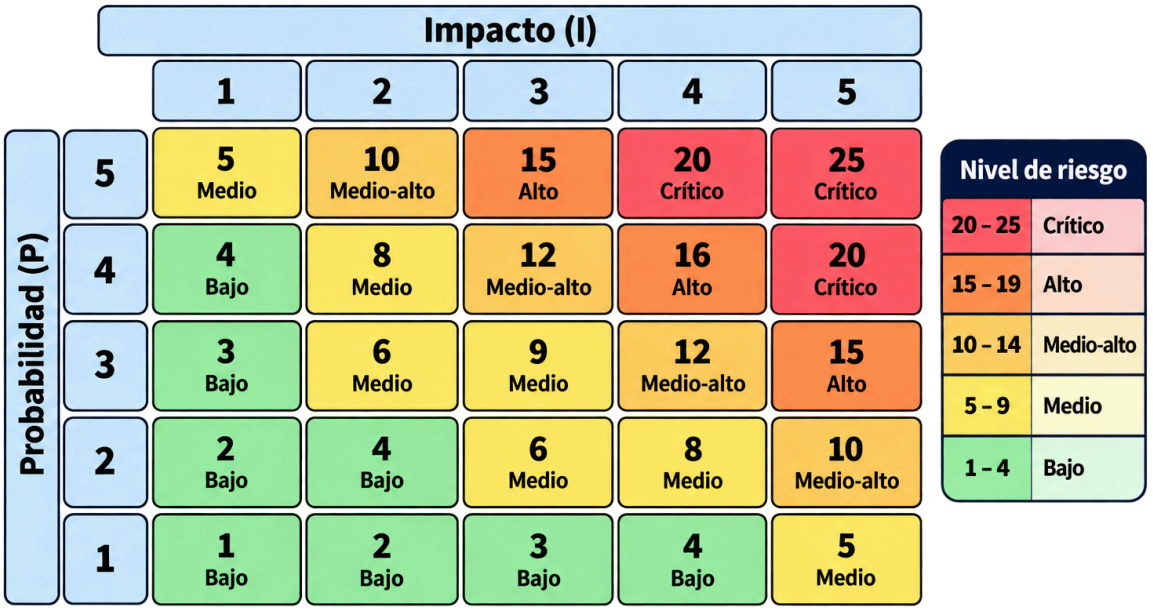


Figura 1. Matriz de riesgos 5 x 5

N.	Riesgo	P	I	Nivel
1	Ingreso no autorizado a salas privadas debido a la exposición de sus claves de acceso almacenadas en texto plano.	4	4	16 - Alto
2	Pérdida de confidencialidad de los mensajes cifrados por exposición de claves criptográficas incluidas en el código fuente.	4	5	20 - Crítico
3	Pérdida de trazabilidad de accesos indebidos debido a la eliminación o manipulación de registros de auditoría.	3	4	12 - Medio-alto
4	Acceso no autorizado al panel administrativo mediante el descubrimiento automatizado de contraseñas.	4	5	20 - Crítico

5	Creación o modificación de salas por usuarios comunes mediante solicitudes directas a funciones administrativas sin verificación de roles.	**4**	**4**	**16 - Alto**
6	Distribución no detectada de información oculta en imágenes manipuladas mediante técnicas de esteganografía.	**3**	**4**	**12 - Medio-alto**
7	Exposición de conversaciones privadas por interceptación de mensajes transmitidos mediante conexiones WebSocket sin cifrar.	**4**	**5**	**20 - Crítico**
8	Ingreso de usuarios no autorizados a salas privadas mediante intentos automatizados de claves de acceso.	**4**	**4**	**16 - Alto**
9	Distribución de archivos maliciosos entre participantes debido a una validación insuficiente de los archivos multimedia cargados.	**4**	**4**	**16 - Alto**
10	Interrupción del servicio de mensajería por agotamiento de conexiones y recursos del servidor.	**4**	**3**	**12 - Medio-alto**
11	Exposición o modificación no autorizada de información de usuarios y salas mediante el uso indebido de credenciales con privilegios excesivos en la base de datos.	**3**	**5**	**15 - Alto**
12	Filtración de archivos multimedia privados mediante el acceso directo a directorios de almacenamiento sin controles de autorización.	**4**	**4**	**16 - Alto**
13	Incumplimiento de la restricción de dispositivo único debido al establecimiento de sesiones simultáneas de una misma cuenta.	**4**	**3**	**12 - Medio-alto**
14	Alteración de la integridad de conversaciones privadas mediante la inserción de mensajes por usuarios que no pertenecen a la sala.	**3**	**4**	**12 - Medio-alto**
15	Superación del límite de participantes configurado debido al registro concurrente de usuarios sin una validación atómica del cupo.	**3**	**3**	**9 - Medio**

Tabla 2. Análisis y evaluación de riesgos identificados en el proyecto

2.2.3. Tratamiento

N.	Riesgo	Tratamiento
1	Ingreso no autorizado a salas privadas debido a la exposición de sus claves de acceso almacenadas en texto plano.	Implementar el almacenamiento seguro de las claves de acceso a las salas mediante el algoritmo de hashing Argon2id, utilizando una sal aleatoria única para cada clave y restringiendo el acceso a los registros de configuración.
2	Pérdida de confidencialidad de los mensajes cifrados por exposición de claves criptográficas incluidas en el código fuente.	Almacenar las claves criptográficas en un gestor de secretos externo al código fuente, aplicar permisos mínimos y establecer mecanismos de rotación y revocación de claves comprometidas.
3	Pérdida de trazabilidad de accesos indebidos debido a la eliminación o manipulación de registros de auditoría.	Centralizar los registros de auditoría en un almacenamiento separado, con permisos de solo escritura para la aplicación, acceso restringido y mecanismos de detección de modificaciones.
4	Acceso no autorizado al panel administrativo mediante el descubrimiento automatizado de contraseñas.	Implementar autenticación multifactor (MFA), limitar los intentos fallidos de inicio de sesión y aplicar retrasos progresivos y bloqueos temporales ante intentos sospechosos.
5	Creación o modificación de salas por usuarios comunes mediante solicitudes directas a funciones administrativas sin verificación de roles.	Implementar control de acceso basado en roles, verificando en el servidor los permisos administrativos en cada operación de creación, modificación y eliminación de salas.
6	Distribución no detectada de información oculta en imágenes manipuladas mediante técnicas de esteganografía.	Implementar un análisis del contenido de las imágenes mediante técnicas de estegoanálisis (análisis estadístico de bits menos significativos y de entropía) y sanitizar cada imagen aceptada recodificándola y eliminando sus metadatos; los archivos sospechosos se colocarán en cuarentena, con generación de alertas y registro de auditoría del evento.
7	Exposición de conversaciones privadas por interceptación de mensajes transmitidos mediante conexiones WebSocket sin cifrar.	Exigir el uso de WebSocket sobre TLS 1.3 (wss://) con certificados válidos, rechazar las conexiones ws://, aplicar HSTS y validar el encabezado Origin, además de cifrar el contenido de cada

		mensaje con un esquema autenticado (AES-256-GCM) para garantizar confidencialidad, integridad y autenticidad.
8	Ingreso de usuarios no autorizados a salas privadas mediante intentos automatizados de claves de acceso.	Limitar los intentos fallidos de ingreso por dirección IP, dispositivo y sala, aplicando retrasos progresivos y bloqueos temporales, exigir una longitud y complejidad mínimas a las claves de acceso, y registrar y alertar los intentos fallidos repetidos.
9	Distribución de archivos maliciosos entre participantes debido a una validación insuficiente de los archivos multimedia cargados.	Validar el tipo real de cada archivo mediante su firma (magic bytes) contra una lista blanca de formatos, limitar su tamaño, analizarlo con un motor antimalware y almacenarlo con nombres aleatorios en un directorio sin permisos de ejecución.
10	Interrupción del servicio de mensajería por agotamiento de conexiones y recursos del servidor.	Establecer límites de conexiones simultáneas por cliente y por dirección IP, limitar la tasa y el tamaño de los mensajes, cerrar las conexiones inactivas mediante timeouts y delegar la protección perimetral a un proxy inverso con monitoreo y alertas de consumo de recursos.
11	Exposición o modificación no autorizada de información de usuarios y salas mediante el uso indebido de credenciales con privilegios excesivos en la base de datos.	Aplicar el principio de mínimo privilegio: la cuenta de la aplicación tendrá solo los permisos necesarios (SELECT, INSERT, UPDATE y DELETE sobre las tablas requeridas), sin permisos administrativos ni de modificación de esquema. Se usarán cuentas separadas para migraciones y administración. Las credenciales se guardarán en un gestor de secretos con rotación periódica, y la base de datos se aislará en una red interna, con registro de consultas privilegiadas.
12	Filtración de archivos multimedia privados mediante el acceso directo a directorios de almacenamiento sin controles de autorización.	Mover el almacenamiento fuera del directorio público y entregar los archivos mediante un endpoint que valide la sesión y la pertenencia del usuario a la sala. Se usarán URLs firmadas con expiración corta, nombres de archivo aleatorios y se deshabilitará el listado de directorios.
13	Incumplimiento de la restricción de dispositivo único debido al establecimiento de sesiones	Verificar en el servidor, al crear una sesión, si el usuario ya tiene una activa,

	simultáneas de una misma cuenta.	y aplicar la política definida (rechazar el nuevo ingreso o invalidar la sesión anterior). Se agregará una restricción única en base de datos para la sesión activa por usuario, tokens vinculados al dispositivo, expiración por inactividad y registro de auditoría de los intentos.
14	Alteración de la integridad de conversaciones privadas mediante la inserción de mensajes por usuarios que no pertenecen a la sala.	Derivar la sala y el usuario desde la sesión autenticada en el servidor, sin confiar en el identificador enviado por el cliente, y verificar la pertenencia antes de aceptar cada mensaje. Se incluirán el identificador de sala y de remitente como datos autenticados adicionales (AAD) en AES-256-GCM, y se registrarán y alertarán los intentos rechazados.
15	Superación del límite de participantes configurado debido al registro concurrente de usuarios sin una validación atómica del cupo.	Unificar la verificación del cupo y el registro del participante en una sola operación atómica, mediante una transacción con bloqueo de fila (SELECT ... FOR UPDATE) o un incremento condicional. Se reforzará con una restricción a nivel de base de datos y pruebas de concurrencia.

Tabla 3. Tabla de tratamiento por riesgo

2.2.4. Medición del riesgo residual

N.	Riesgo	Inicial	Residual	Estado
1	Ingreso no autorizado a salas privadas debido a la exposición de sus claves de acceso almacenadas en texto plano.	**16**	**8**	**Medio**
2	Pérdida de confidencialidad de los mensajes cifrados por exposición de claves criptográficas incluidas en el código fuente.	**20**	**5**	**Medio**
3	Pérdida de trazabilidad de accesos indebidos debido a la eliminación o manipulación de registros de auditoría.	**12**	**4**	**Bajo**
4	Acceso no autorizado al panel administrativo mediante el descubrimiento automatizado de contraseñas.	**20**	**5**	**Medio**
5	Creación o modificación de salas por usuarios comunes mediante solicitudes directas a funciones administrativas sin verificación de roles.	**16**	**4**	**Bajo**

6	Distribución no detectada de información oculta en imágenes manipuladas mediante técnicas de esteganografía.	**12**	**8**	**Medio**
7	Exposición de conversaciones privadas por interceptación de mensajes transmitidos mediante conexiones WebSocket sin cifrar.	**20**	**4**	**Bajo**
8	Ingreso de usuarios no autorizados a salas privadas mediante intentos automatizados de claves de acceso.	**16**	**8**	**Medio**
9	Distribución de archivos maliciosos entre participantes debido a una validación insuficiente de los archivos multimedia cargados.	**16**	**6**	**Medio**
10	Interrupción del servicio de mensajería por agotamiento de conexiones y recursos del servidor.	**12**	**6**	**Medio**
11	Exposición o modificación no autorizada de información de usuarios y salas mediante el uso indebido de credenciales con privilegios excesivos en la base de datos.	**15**	**5**	**Medio**
12	Filtración de archivos multimedia privados mediante el acceso directo a directorios de almacenamiento sin controles de autorización.	**16**	**4**	**Bajo**
13	Incumplimiento de la restricción de dispositivo único debido al establecimiento de sesiones simultáneas de una misma cuenta.	**12**	**3**	**Bajo**
14	Alteración de la integridad de conversaciones privadas mediante la inserción de mensajes por usuarios que no pertenecen a la sala.	**12**	**4**	**Bajo**
15	Superación del límite de participantes configurado debido al registro concurrente de usuarios sin una validación atómica del cupo.	**9**	**3**	**Bajo**

Tabla 4. Tabla de medición de riesgo residual

3. Conclusiones

El análisis de los 15 activos identificados en la aplicación de salas de chat seguras permitió evaluar el riesgo inicial de cada amenaza mediante la matriz 5 x 5 (R = P x I). Antes de aplicar controles, 3 riesgos se ubicaron en nivel Crítico, 6 en nivel Alto, 5 en nivel Medio-alto y 1 en nivel Medio, es decir, 14 de los 15 riesgos estaban en niveles Medio-alto o superiores.

Los riesgos críticos corresponden a la exposición de las claves criptográficas en el código fuente, el descubrimiento automatizado de contraseñas del administrador y el uso de WebSocket sin cifrar. Estos tres afectan directamente la confidencialidad de las comunicaciones y el control administrativo, que son los pilares del proyecto, por lo que se priorizaron en el tratamiento.

Finalmente, el tratamiento solo reduce el riesgo si los controles se implementan y se verifican. Se recomienda validarlos mediante pruebas de seguridad, revisar esta evaluación cuando cambie la arquitectura de la aplicación o aparezcan nuevas amenazas.

4. Referencias

Biryukov, A., Dinu, D., & Khovratovich, D. (2021). *Argon2: the memory-hard function for password hashing and other applications* (RFC 9106). Internet Engineering Task Force. https://www.rfc-editor.org/info/rfc9106

OWASP Foundation. (2021). *OWASP Top 10:2021*. https://owasp.org/Top10/

OWASP Foundation. (s. f.). *Password storage cheat sheet*. OWASP Cheat Sheet Series. https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html